

Basic Security Report for Zynxis

Prepared by Amina Sheikh — Final Capstone, Zynxis Cybersecurity Internship

Introduction

Over the past eight weeks of this internship, I worked through the same categories of attacks and defenses that a small company like Zynxis actually deals with day to day — from SQL Injection and XSS on DVWA, to password cracking, network scanning with Nmap, and reading live traffic in Wireshark. This report brings those lessons together into a practical security overview for Zynxis: the top 5 threats the company could realistically face, how to defend against each one, what to do if Zynxis is ever hacked, and three free tools worth setting up right away.

Part 1: Top 5 Cyber Threats Facing Zynxis

1. Phishing Attacks

Phishing is a fake email or message designed to look legitimate, aimed at tricking an employee into handing over a password or clicking something malicious. It doesn't rely on any technical weakness in Zynxis's systems — it relies on a person, in a busy moment, not double-checking a sender's address. That is exactly why it is usually the easiest way in for an attacker, and why most companies list it as their number one risk.

2. Malware and Ransomware

Ransomware locks or encrypts a company's files and demands payment to release them. It typically arrives through an infected attachment, a bad download, or a compromised site. For a small team like Zynxis, this isn't just an inconvenience — if the wrong machine gets hit and there's no recent backup, work can stop entirely until it's resolved.

3. Weak Passwords and Brute Force Attacks

During this internship, I ran a small password-cracking exercise using MD5 hashes: a common password like "password123" was cracked almost instantly, while four longer, randomized passwords were not cracked at all. That difference is the whole story of this threat. Brute force attacks work by trying combination after combination, and weak or reused passwords are exactly what makes that practical for an attacker.

4. Web Application Vulnerabilities (SQL Injection and XSS)

I practiced both of these directly on DVWA. With SQL Injection, entering `1' OR '1'='1` into a login field returned every user in the database instead of just one — because the input was passed straight into the query with no filtering. With XSS, a simple `<script>alert('hacked')</script>` in a text field executed in the browser instead of being treated as plain text. If Zynxis runs any website or internal tool, the same root cause applies: user input that isn't checked before it's used.

5. Unpatched or Outdated Software

Old software keeps security flaws that have already been fixed in newer versions — and attackers know exactly where to look for them. This covers everything from the operating system down to browser plugins and any third-party tools Zynxis depends on. It's a quiet risk because nothing looks broken; the system just hasn't been told to fix what's already known to be wrong.

Part 2: How to Stay Safe From Each Threat

1. Protecting Against Phishing

- Check the sender's actual email address, not just the display name, before trusting a message.
- Don't click links or open attachments from senders you weren't expecting to hear from.
- Treat urgency as a warning sign — real requests rarely demand action in the next five minutes.
- Report anything suspicious to IT/Security rather than forwarding or replying to it directly.

2. Protecting Against Malware and Ransomware

- Keep antivirus active and updated on every company device, not just the ones that feel "important."
- Avoid downloading software from anywhere other than the official source.
- Keep backups of important files somewhere separate from the main network, so a ransomware infection can't reach them too.
- Treat unexpected attachments as suspicious even if the email looks work-related.

3. Protecting Against Weak Passwords and Brute Force

- Require at least 12 characters, mixing uppercase, lowercase, numbers, and symbols — the cracking test above showed exactly why length and randomness matter.
- Turn on Two-Factor Authentication everywhere it's available.
- Lock accounts out after a small number of failed login attempts.
- Never reuse one password across multiple systems.

4. Protecting Against Web Application Vulnerabilities

- Use prepared statements/parameterized queries so user input is never treated as part of a database command — this is the direct fix for the SQL Injection shown earlier.
- Sanitize and encode any user input before it's displayed back on a page, to stop XSS from executing.
- Add a Content Security Policy (CSP) as an extra layer, so even if a script slips through, the browser won't run it.
- Test any company website or internal tool for these issues periodically, not just once at launch.

5. Protecting Against Unpatched Software

- Turn on automatic updates wherever it's an option.
- Set a routine for checking and applying patches, rather than waiting for something to break.

- Retire software that's no longer supported by its developer instead of leaving it running.

Part 3: Incident Response Plan — What to Do If Zynxis Gets Hacked

If something does go wrong, having a clear order of steps matters more than having a perfect one. Here is what Zynxis should follow:

- 1. Identify and Contain** — Notice the signs (locked files, strange account activity, systems behaving oddly) and disconnect the affected device or account from the network immediately, before anything spreads further.
- 2. Report Internally** — Tell the IT/Security team right away. This is not something to quietly try to fix alone first.
- 3. Change Credentials** — Reset passwords for anything that might be compromised, from a different, trusted device.
- 4. Assess the Damage** — Figure out what was actually affected: which systems, which data, and whether anything sensitive was exposed.
- 5. Remove the Threat** — Run antivirus/anti-malware scans on affected systems, or restore from a clean backup if the damage is too deep to trust the system as-is.
- 6. Recover Systems** — Only bring things back online once you're confident they're actually clean.
- 7. Review and Improve** — Work out how it happened, and close that specific gap so it can't happen the same way twice.

Part 4: 3 Free Tools Zynxis Should Use for Security

1. Antivirus — Windows Defender

Windows Defender comes built into every Windows machine, so there's no extra cost or setup barrier to using it. It scans for and removes malware, ransomware, and spyware in the background. For a small team, this is the simplest first layer of defense to have running everywhere, with no excuse not to.

2. Firewall — Windows Defender Firewall

A firewall controls what network traffic is allowed in and out of a device. Windows Defender Firewall is already included on every Windows machine — it just needs to actually be turned on and left that way, rather than disabled for convenience, which is a mistake I've seen mentioned often in basic security guidance.

3. Password Manager — Bitwarden

Bitwarden is free, open-source, and solves the exact problem shown in the password-cracking exercise earlier in this report: it generates and stores long, random, unique passwords so employees never have to fall back on something memorable (and therefore guessable). Rolling this out company-wide would directly close the weakest link identified in Part 1.

Conclusion

Nothing in this report requires an advanced attack to be relevant — every threat covered here is common, and every fix is realistic for a small team to actually implement. What stood out most from working through this internship is how often the root cause repeats itself: unchecked input, a weak password, an unpatched system, someone trusting an email they shouldn't have. Fixing those basics, consistently, is most of what real security work looks like.